

CSO7018 Ethical Hacking

Lab Questions and Answers

Student ID: 2416509

This document provides structured answers to the practical lab questions arising from the CSO7018 VM Lab Practical Activities. All answers are based on authorised activities performed inside the Apporto/GNS3 lab environment using Kali Linux, Ubuntu, and Metasploitable 2 virtual machines.

Unit 2 – OSINT and Reconnaissance

Q1. What was the purpose of using Maltego in the OSINT activity?

Maltego was used to demonstrate how publicly available information can be collected, visualised, and correlated during an OSINT investigation. Its graph-based interface helps investigators link entities such as names, domains, websites, email addresses, organisations, and infrastructure. In this lab, Maltego supported safe intelligence-gathering practice without directly attacking a target system.

Q2. Why is OSINT important before active scanning?

OSINT helps define the target profile before active technical testing begins. It can reveal domains, IP ranges, technologies, public accounts, and relationships that guide later reconnaissance. This reduces unnecessary scanning, improves scope control, and supports a more professional penetration-testing workflow.

Q3. What ethical controls were applied during OSINT work?

The OSINT work was restricted to the authorised lab task and publicly accessible information. No private accounts were accessed, no credentials were collected, and no attempt was made to bypass authentication or privacy controls. The activity remained within the university-approved Apporto lab context and was documented as educational evidence.

Q4. What information did DNS tools such as nslookup help identify?

DNS tools helped identify records associated with a target domain, including A records, MX records, and NS records where available. These records can reveal IP addresses, mail servers, and authoritative name servers. In a real assessment, this information helps map the target's external infrastructure and identify systems requiring further review.

Q5. What is the difference between passive and active reconnaissance?

Passive reconnaissance gathers information without directly interacting with the target system, for example through public records, search engines, or OSINT platforms. Active reconnaissance involves direct interaction with systems, such as ping sweeps, port scanning, or banner grabbing. Passive methods are usually lower risk, while active methods require clearer authorisation and scope control.

Unit 3 – Linux Networking, Nmap, hping3 and Netcat

Q6. What did the Kali Linux IP configuration confirm?

The Kali Linux IP configuration confirmed that the attacker VM was connected to the isolated host-only lab network. The attacker VM used IP address 192.168.122.148, while the Metasploitable 2 target was identified as 192.168.122.108. This confirmed that testing was conducted within the controlled Apporto/GNS3 environment.

Q7. What was the purpose of the Nmap ping sweep?

The Nmap ping sweep was used for host discovery across the isolated subnet 192.168.122.0/24. It identified live hosts including the Kali Linux attacker VM, Ubuntu VM, Apporto/GNS3 host, and Metasploitable 2 target. This step confirmed which systems were active before service enumeration began.

Q8. What did the Nmap service/version scan reveal?

The Nmap service/version scan against 192.168.122.108 identified 23 open services on the Metasploitable 2 host. Important services included FTP on port 21 running vsftpd 2.3.4, SSH on port 22, Telnet on port 23, Apache HTTP on port 80, Samba services on ports 139 and 445, MySQL on port 3306, PostgreSQL on port 5432, VNC on port 5900, and UnrealIRCd on port 6667.

Q9. Why is service/version detection important?

Service/version detection is important because vulnerabilities are often tied to specific software versions. Identifying that FTP was running vsftpd 2.3.4 enabled correlation with CVE-2011-2523, a known backdoor vulnerability. Without version detection, vulnerability assessment would be less accurate and remediation recommendations would be weaker.

Q10. What did Netcat banner grabbing confirm?

Netcat banner grabbing confirmed the FTP service banner from the target host. The command connected to port 21 and returned “220 (vsFTPd 2.3.4)”. This provided independent evidence that the FTP service version matched the vulnerable vsftpd 2.3.4 software identified by Nmap and later confirmed during exploitation.

Q11. What is the value of using more than one tool for evidence collection?

Using multiple tools improves reliability through cross-tool corroboration. In this lab, Nmap identified the FTP service, Netcat confirmed the raw banner, Nessus mapped the vulnerability to CVE/CVSS information, and Metasploit validated exploitability. This creates a stronger evidential chain than relying on one tool alone.

Q12. What risks are associated with open services such as FTP, Telnet, and rlogin?

FTP, Telnet, and rlogin are legacy services that may transmit credentials or commands insecurely and can expose systems to brute-force attacks, information disclosure, or remote exploitation. Telnet and rlogin should generally be disabled in favour of SSH, while FTP should be replaced with secure alternatives such as SFTP or FTPS where required.

Unit 4 – Nessus Vulnerability Scanning

Q13. What was the purpose of using Nessus Essentials?

Nessus Essentials was used to perform an automated vulnerability assessment against the authorised Metasploitable 2 target. It helped identify vulnerabilities, severity ratings, CVSS scores, and remediation guidance. This complemented manual reconnaissance and provided structured vulnerability evidence for the report.

Q14. How was the Nessus scan scoped safely?

The Nessus scan was configured to target only the authorised Metasploitable 2 IP address: 192.168.122.108. This ensured the assessment remained within the controlled lab environment and avoided scanning external, personal, or production systems. The scope was therefore aligned with ethical hacking practice and university requirements.

Q15. What did the Nessus scan results show?

The Nessus scan showed a large number of findings against the intentionally vulnerable Metasploitable 2 system. The newer scan evidence showed 71 vulnerabilities, including 11 Critical, 6 High, 26 Medium, 9 Low, and 139 Informational findings. These results demonstrate the high-risk exposure of the lab target and the importance of patch management and service hardening.

Q16. Why are CVSS scores useful in vulnerability management?

CVSS scores provide a standardised method for rating vulnerability severity. They help prioritise remediation based on risk. In this lab, critical vulnerabilities such as vsftpd 2.3.4 received high severity ratings because they can enable unauthenticated remote compromise. CVSS therefore supports defensible prioritisation of security fixes.

Q17. What is CVE-2011-2523 and why is it critical?

CVE-2011-2523 is a backdoor vulnerability in vsftpd 2.3.4. It is critical because an attacker can trigger a backdoor service and obtain remote shell access without valid credentials. In the lab, this vulnerability was identified through service enumeration and validated using Metasploit, resulting in root-level access on the target.

Q18. What remediation should be recommended for the vsftpd 2.3.4 vulnerability?

The vulnerable vsftpd 2.3.4 service should be removed or replaced with a trusted, patched version. If FTP is not required, the service should be disabled completely. If file transfer is required, secure alternatives such as SFTP or FTPS should be used. Network segmentation and firewall rules should also restrict access to administrative or legacy services.

Unit 4 – Metasploit Exploitation

Q19. Why was Metasploit used in the exploitation phase?

Metasploit was used to validate whether the identified vsftpd 2.3.4 vulnerability was practically exploitable. The exploit/unix/ftp/vsftpd_234_backdoor module was selected because it directly matches the vulnerable service version identified during enumeration. This confirmed exploitability in a controlled and authorised lab setting.

Q20. What settings were configured before running the exploit?

The exploit module was configured with RHOSTS set to 192.168.122.108 and RPORT set to 21. These settings ensured that the Metasploit module targeted only the authorised Metasploitable 2 FTP service within the lab environment.

Q21. What evidence confirmed successful exploitation?

Successful exploitation was confirmed when Metasploit reported that the backdoor service was spawned and a command shell session was opened from Kali Linux to the target. Running `whoami` returned `root` and running `id` returned `uid=0(root) gid=0(root)`, confirming root-level compromise of the Metasploitable 2 target.

Q22. Why was post-exploitation limited?

Post-exploitation was limited to privilege verification only. The commands `whoami` and `id` were sufficient to prove compromise without modifying files, installing persistence, collecting data, or damaging the system. This reflects safe professional practice and ensures the activity remains ethical, controlled, and educational.

Q23. What does root-level access imply from a risk perspective?

Root-level access means complete administrative control over the target system. An attacker with root privileges could read or modify files, install malware, create users, pivot to other systems, or disrupt services. In the lab, this demonstrated the severe impact of leaving critical vulnerabilities unpatched.

Overall Reflection and Evaluation

Q24. What was the overall attack chain demonstrated in the lab?

The lab demonstrated a complete attack chain: scope definition, OSINT, host discovery, service enumeration, vulnerability identification, vulnerability validation, controlled exploitation, and evidence documentation. This mirrors a professional penetration-testing lifecycle while remaining within a safe lab environment.

Q25. How was effectiveness evaluated?

Effectiveness was evaluated through evidence quality and cross-tool validation. The target was discovered with Nmap, vulnerable services were enumerated with Nmap and Netcat, Nessus mapped findings to CVEs and severity scores, and Metasploit validated exploitability. This provided technical confidence that the findings were real and reproducible.

Q26. What were the main lessons learned?

The main lessons learned were that reconnaissance and enumeration are essential before exploitation, service versions can directly reveal critical vulnerabilities, automated scanners must be validated with manual

evidence, and exploitation must always remain within authorised scope. The lab also showed how poor patch management and legacy services can lead to full system compromise.

Q27. What ethical and legal principles applied throughout the assessment?

The assessment followed authorisation, scope control, proportionality, non-destruction, and responsible documentation. All testing was conducted only within the Apporto/GNS3 lab environment. No external systems were scanned, no personal data was collected, and no persistence or destructive action was performed. The work was aligned with the Computer Misuse Act 1990 and Data Protection Act 2018.

Q28. What final remediation priorities should be recommended?

The highest priority is to remove or patch vsftpd 2.3.4 due to CVE-2011-2523. Legacy services such as Telnet, rlogin, and insecure FTP should be disabled or replaced with secure alternatives. Samba, Apache, database, and remote-access services should be patched and restricted. Network segmentation, least privilege, firewall rules, vulnerability scanning, and regular patch management should be implemented.

References

Computer Misuse Act 1990 (c.18) UK Parliament. Available at:

<https://www.legislation.gov.uk/ukpga/1990/18/contents> [Accessed: 22 May 2026].

FIRST.org (2024) CVSS v3.1 Specification Document. Available at: <https://www.first.org/cvss/> [Accessed: 22 May 2026].

Kennedy, D., O’Gorman, J., Kearns, D. and Aharoni, M. (2011) Metasploit: The Penetration Tester’s Guide. San Francisco: No Starch Press.

Lyon, G.F. (2009) Nmap Network Scanning. Nmap Project.

National Vulnerability Database (2024) CVE-2011-2523. NIST. Available at:

<https://nvd.nist.gov/vuln/detail/CVE-2011-2523> [Accessed: 22 May 2026].

Tenable (2024) Nessus Essentials User Guide. Available at: <https://docs.tenable.com/nessus/> [Accessed: 22 May 2026].

UK Government (2018) Data Protection Act 2018. Available at:

<https://www.legislation.gov.uk/ukpga/2018/12/contents> [Accessed: 22 May 2026].